

Management Groups & Azure Policy: Governance at Scale

Organize subscriptions and enforce compliance automatically across your entire organization

 Intermediate

 15 Minutes

 AZ-104 · Module 01

Why This Matters

Imagine managing 50 subscriptions across multiple teams. Applying RBAC to each one individually would take forever. Management Groups let you apply policies and permissions to all subscriptions at once. Azure Policy then enforces rules automatically (e.g., "all VMs must be encrypted"). Together, they're how enterprises scale governance.

Before You Start

Prerequisites	02-RBAC Fundamentals (must understand RBAC first)
Time to understand	15 minutes
Difficulty	 Intermediate (builds on RBAC)
What you'll learn	How to organize subscriptions, enforce compliance at scale

Management Groups vs. Resource Groups vs. Subscriptions

This is confusing for beginners, so let's clarify with an analogy.

Building Hierarchy Analogy:

Each **subscription** can contain multiple **resource groups**, and **resource groups** contain actual resources (VMs, storage, etc.).

```
Company (Management Group)
├─ Finance Department (Management Group)
│   ├── Accounting Subscription
│   └─ Billing Subscription
├─ Engineering Department (Management Group)
│   ├── Dev Subscription
│   ├── QA Subscription
│   └─ Prod Subscription
└─ Operations (Management Group)
    ├── Ops Subscription
    └─ Backup Subscription
```

What Is a Management Group?

A **Management Group** is a **container for subscriptions**. It lets you:

- Apply the same RBAC roles to multiple subscriptions at once
- Apply the same policies to multiple subscriptions at once
- Organize subscriptions by department, business unit, or environment

What Is Azure Policy?

Azure Policy = Automated compliance rules that run continuously.

Example policy:

```
"All virtual machines must have encryption enabled"
```

What happens:

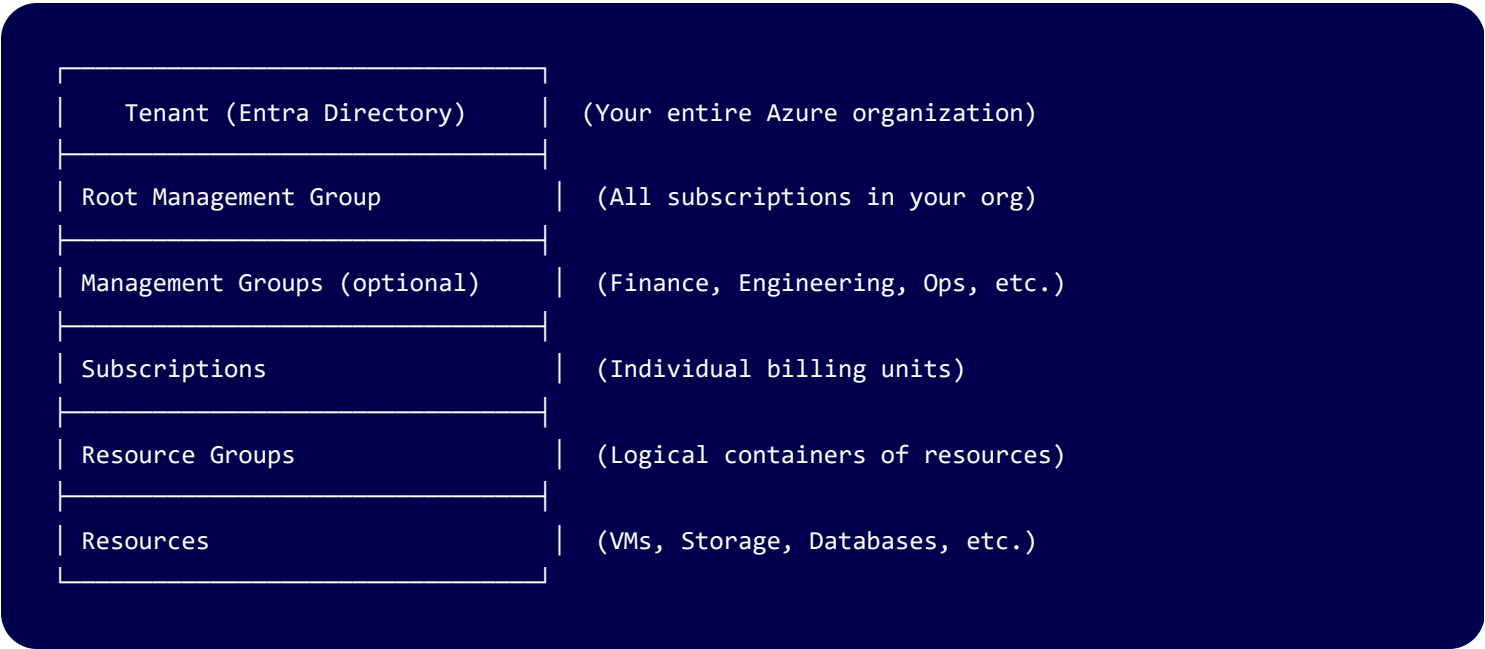
- If someone creates a VM WITHOUT encryption → Policy blocks it
- If someone removes encryption from a VM → Policy marks it as non-compliant

- Admin gets audit trail showing who violated the policy and when

The Hierarchy: Azure's Organizational Structure

The Full Chain (Top to Bottom)

Key insight: Permissions and policies flow **downward**. If you set a policy on a management group, it applies to all subscriptions below it.



How Management Groups Work

Real Scenario: TechCorp Organization

TechCorp has:

- Finance team: 2 subscriptions (Accounting, Billing)
- Engineering: 3 subscriptions (Dev, QA, Prod)
- Operations: 2 subscriptions (Ops, Backup)

Without management groups: Admin must set policies individually on 7 subscriptions (tedious, error-prone).

With management groups:

```
Root Management Group (TechCorp)
├── Finance MG
│   ├── Accounting Sub (Policy applies automatically)
│   └── Billing Sub (Policy applies automatically)
├── Engineering MG
│   ├── Dev Sub (Policy applies automatically)
│   ├── QA Sub (Policy applies automatically)
│   └── Prod Sub (Policy applies automatically)
└── Operations MG
    ├── Ops Sub (Policy applies automatically)
    └── Backup Sub (Policy applies automatically)
```

Admin applies one policy at the root level → All 7 subscriptions inherit it automatically.

How Azure Policy Works

Policy = Automated Compliance Rule

Example Policy: "All virtual machines must have encryption enabled"

Azure Policy: VM Encryption Required

```
IF: Someone creates a VM
AND: Encryption is NOT enabled
THEN: Block the VM creation (deny)
```

```
OR (depending on policy):
THEN: Create the VM but mark as non-compliant
```

Policy Actions: Deny vs. Audit

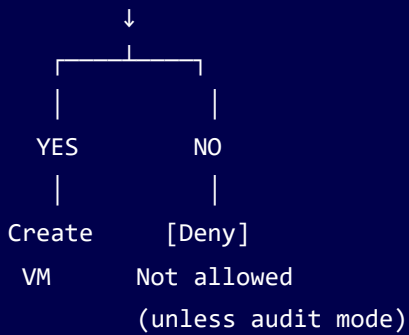
Action	What Happens	Use Case
Deny	Block non-compliant action	Critical security rules (encryption, firewall)
Audit	Allow action, but log it as non-compliant	Monitor violations before enforcing
Modify	Automatically fix it	Add tags, enable monitoring, etc.

Common Azure Policies

Policy	What It Enforces	Example
Encryption Required	All storage must use encryption	Block unencrypted storage accounts
Tag Enforcement	All resources must have specific tags	Require "Owner" and "CostCenter" tags
Allowed Locations	Resources can only be created in certain regions	Only allow East US and West US
SKU Restrictions	Resources can only use approved sizes	Only allow Standard_B1s or larger VMs
HTTPS Required	All web apps must use HTTPS	Block HTTP-only apps

Mental Model: Policy as a Gatekeeper





Worked Example: Real Scenario

The Scenario

Company Goal:

- All VMs must have backup enabled (compliance requirement)
- All resources must be tagged with Department and CostCenter (for billing)
- Only approved VM sizes to control costs

Without Policy

- Admin must manually check each VM (error-prone)
- Some VMs get overlooked
- Billing tags missing on some resources
- Result: Compliance violations and unclear costs

With Policy

- Policies automatically enforce these rules
- Violations are immediately visible
- Non-compliant resources are highlighted

Implementation

Step 1: Create Management Group Structure

```
Root (TechCorp)
├─ Finance MG
├─ Engineering MG
└─ Operations MG
```

Step 2: Apply Policies at Root Level

```
Policy 1: "All VMs must have backup enabled"
- Action: Deny non-compliant VM creation
- Scope: Root (applies to all subscriptions)
```

```
Policy 2: "All resources must have tags"
- Action: Audit first, then Deny after 30 days
- Required tags: Department, CostCenter
- Scope: Root (applies to all subscriptions)
```

```
Policy 3: "Only Standard_B2s or larger VMs allowed"
- Action: Deny small VM creation (too costly)
- Scope: Root (applies to all subscriptions)
```

Step 3: Result

```
Developer tries to create:
├─ VM without backup → Policy DENIES (backup required)
├─ VM without tags → Policy DENIES (tags required)
├─ VM size: Standard_B1s → Policy DENIES (too small)
└─ VM with everything correct → VM is created ✓
```

Step 4: Compliance Dashboard

```
Management Group: Engineering
├─ Dev Subscription: 2 non-compliant resources
│   └─ web-app-1 (missing CostCenter tag)
├─ QA Subscription: Compliant
└─ Prod Subscription: 1 non-compliant resource
    └─ db-server-1 (backup not enabled)
```

Admin can see at a glance what needs fixing.

Common Mistakes (What NOT to Do)

✗ Mistake 1: Overly Strict Policy (Deny Everything)

Wrong

```
Policy: "Deny all VM creation"
```

↓

```
No one can create VMs (including legitimate business needs)
```

↓

```
Team stuck, can't deploy applications
```

Fix

```
Use audit mode first:
```

- Set policy to "Audit" (log violations, don't deny)
- Review violations for 2-4 weeks
- See what legitimate use cases exist
- Adjust policy to allow legitimate actions
- Switch to "Deny" mode once tuned

Why it fails: Policies that are too strict block legitimate work.

✗ Mistake 2: Inconsistent Management Group Structure

Wrong

```
Some subscriptions organized by department
```

```
Other subscriptions organized by environment
```

```
Some subscriptions not in any management group
```

```
Result: Policies apply inconsistently
```

Fix

- Plan structure carefully:
- All subscriptions must be in a management group
 - Use consistent structure (by department, by environment, or both)
 - Document the structure so others understand it

Why it fails: Inconsistent structure = inconsistent governance.

✗ Mistake 3: Creating Policy But Never Reviewing It

Wrong

Set policy, forget about it
↓
6 months later, policy blocks legitimate business need
↓
Team calls admin: "This policy is breaking our work!"

Fix

- Set up regular reviews (quarterly):
- Check policy compliance reports
 - Review denied/blocked requests
 - Adjust policies if they're too strict
 - Document changes

Why it fails: Policies need maintenance.

Summary: Management Groups vs. Resource Groups

Aspect	Management Group	Resource Group
Purpose	Organize subscriptions	Organize resources
Contains	Subscriptions	Resources (VMs, storage, etc.)

Policies	Policies apply to all subscriptions within it	N/A (policies apply via management groups)
RBAC	Assign roles to all subscriptions at once	Assign roles to specific resources
Use Case	Governance across company	Organization within a subscription

How This Connects to Other Topics

Related to Module 01 (Identity)

- **RBAC + Management Groups:** Assign roles at management group level, inherit across all subscriptions
- **Example:** "Finance team gets Contributor role on Finance management group" → applies to all Finance subscriptions

Related to Module 02 (Storage)

- **Storage Encryption Policy:** Enforce encryption on all storage accounts via policy
- **Storage Access:** Combine policy with RBAC for complete control

Related to Module 04 (Networking)

- **NSG Policy:** Enforce security groups on all resources
- **Allowed Regions:** Use policy to limit resources to specific regions

Related to Module 05 (Monitor)

- **Audit Logging:** See when policies block actions
- **Compliance Reports:** Track which subscriptions violate which policies

See It In Action

Associated lab: Lab 03: Management Groups & Azure Policy

Suggested learning sequence:

1.  Read **RBAC Fundamentals** first
2.  Read this doc (Management Groups & Policy)
3.  Work through Lab 03 (hands-on governance setup)
4.  Read **Access Control Scenarios** (enterprise patterns)

Key Takeaways

Summary

- **Management Groups organize subscriptions** (similar to folders for files)
- **Policies enforce rules automatically** (gates, not manual checks)
- **Policies flow downward** (set at root, applies to all subscriptions)
- **Audit before Deny** (test policies before blocking users)
- **Regular reviews necessary** (adjust policies as business needs change)
- **Structure matters** (consistent organization = consistent governance)

Next Steps

1. **Understand:** Read **RBAC Fundamentals** (prerequisite)
2. **Learn:** Read this doc (you're here)
3. **Practice:** **Lab 03: Management Groups & Azure Policy**
4. **Apply:** **Access Control Scenarios** (enterprise patterns)
5. **Advance:** Optional—Azure Blueprints (pre-packaged governance templates)

© 2026 — AZ-104 Learning Hub. For study purposes only.